Day 2 — System Security & Compliance

> **Activity packet** for your triad. Today's job: run a **STRIDE threat-model pass** at the architecture level, translate the results into **revised security and compliance NFRs**, and add Section 3 of the TCD.

Where we are in the week

Day 1 produced TCD Sections 1–2 (architecture stance, integration map). Today produces Section 3 — the security & compliance constraints. The output supersedes the **first-draft** security NFRs in the PRD's Section 7.

The discipline: a TPM is not the security expert. The job is to drive the right conversation with security and produce a starting threat model that the security team can validate, not start from scratch.

Inputs

- TCD Sections 1–2 from yesterday
- The PRD's Section 7 (NFRs) — the first draft to be replaced
- The PRD's Section 10 (Dependencies) — informs the data-flow boundaries
- The triad's NS, journey map, and any compliance hints from the customer brief

---

STRIDE — the threat-model frame

STRIDE is a memorable taxonomy of threats:

Letter	Threat	Plain language
S	**Spoofing**	Pretending to be someone you aren't
T	**Tampering**	Changing data without authorization
R	**Repudiation**	Denying you did something you did
I	**Information disclosure**	Exposing data to the wrong party
D	**Denial of service**	Blocking legitimate use
E	**Elevation of privilege**	Doing more than your role allows

For each integration boundary in TCD Section 2, the triad asks each of the 6 questions and records the threat + a mitigation.

The "data flow" lens (today's mental model)

A threat model is a walk along the **data flow** of your feature. Where does data come from, where does it move to, where does it stop, and who can read or change it at each step?

For most features:

```
[User] →(auth)→ [Frontend] →(API)→ [Backend service]
                                          ↓
                                     [Datastore]
                                          ↓
                                   [Audit / events]
                                          ↓
                                [Downstream consumer]
```

Threats live at the **arrows** (data in motion) and at the **boxes** (data at rest). Each STRIDE letter applies to one or more.

The three compliance frames you must know

Even at junior-TPM scope, three frames come up constantly:

Framework	What it covers	Where it shows up
SOC 2 Type II	Operational controls (security, availability, confidentiality, processing integrity, privacy)	Most B2B SaaS sales requirements
GDPR / CCPA / state-level US privacy	Personal data handling, consent, deletion	Anywhere you collect or process customer data
Industry-specific	HIPAA (health), PCI-DSS (payments), FERPA (education), SOX (public companies)	When the customer is in that industry

A TPM doesn't write the compliance program. A TPM **flags which frame applies** and **drives the conversation** with the responsible team.

Activity 1 — STRIDE Calibration on a Public Example

Format: Triad • **35 min** • Block 1

Purpose

Practice the STRIDE walk on a feature outside FieldPulse before applying it to your PRD. Calibration first, application second.

Setup

Each triad needs the STRIDE letter card and blank paper for the data-flow sketch. AI optional and provenance-logged if used.

The example

A **password-reset feature** for a generic B2C app:

> User enters email → system sends magic-link → user clicks link → system signs them in → session token issued → user can change password.

The STRIDE pass

For each step in the flow, the triad answers each of the 6 STRIDE questions. You will **not** find a threat for every letter at every step — that's expected. What matters is that the question was asked.

Triad protocol

1. **Sketch the flow** on paper (5 min).
2. **STRIDE walk** (20 min). Per step, per letter: threat? if yes, what? Mitigation?
3. **Cull to top 5** (10 min). Which 5 threats would a security reviewer most likely call out as the biggest risk?

Readout (60 sec per triad)

> "The most surprising threat we found was [X]. The most predictable was [Y]. The one our cohort would disagree on is [Z]."

Deliverable

A STRIDE walk on the password-reset flow with the top-5 threats culled, each named with letter, location, scenario, and a candidate mitigation.

Activity 2 — STRIDE Pass on Your PRD Feature

Format: Triad • **40 min** • Block 2

Purpose

Apply the calibrated STRIDE pass to your triad's PRD feature.

Setup

Each triad needs yesterday's integration table, the PRD Section 5 sketch, and the threat template. AI optional and provenance-logged.

Triad protocol

1. **Re-draw the data flow** (10 min). Use the integration table from yesterday plus the PRD Section 5 sketch.

2. **STRIDE walk** (20 min). Same drill: 6 questions per box and arrow.
3. **Top-5 threats** (10 min). Document each as:

```
### Threat — <short name>
**STRIDE letter:** S / T / R / I / D / E
**Where:** [box or arrow in your data flow]
**Scenario:** [one sentence]
**Likelihood:** L / M / H
**Impact:** L / M / H
**Mitigation:** [specific control; "TLS" is not a
complete answer]
**Owner:** [who will validate this — security team,
you, the architect]
```

What "good" looks like

- Threats reference specific arrows or boxes in your data flow.
- Mitigations are **specific controls**, not "use security best practices."
- At least 2 of the 5 are not Spoofing or Information Disclosure (the easy ones).
- Each threat has an **owner** named for validation.

Deliverable

Top-5 threats documented with letter, scenario, likelihood/impact, specific mitigation, and named owner — pinned to the feature's data flow.

Activity 3 — Compliance Frame + Updated NFRs

Format: Triad • **40 min** • Block 3

Purpose

Identify which compliance frames apply, write the constraints, and use the threat model + compliance to **rewrite the PRD's first-draft Security NFRs**.

Setup

Each triad needs the threat model output, the three compliance-frame cards (SOC 2 / privacy / industry), and the original PRD Section 7 Security & Compliance NFRs.

Triad protocol — Step 1: compliance frame check

For your triad's feature, answer:

- **SOC 2:** Are we handling customer data, audit-relevant actions, or availability commitments? (For most B2B features: yes.)
- **Privacy regime:** Does this touch personal data of EU / California / other regulated residents? Which?
- **Industry-specific:** Is the customer in a regulated industry? Does the data type pull a regime in?

For each "yes": list the **specific control** the framework requires that this feature must respect.

Example for FieldPulse reconcile:

```
- SOC 2: User-action audit trail required (CC7.2).
24-month retention.
- Privacy: Dispatcher PII (name, employee ID)
processed. CCPA applies.
- Industry-specific: None directly; some shops are
CCPA-equivalent state coverage.
```

Triad protocol — Step 2: rewrite the security & compliance NFRs

Take the threat model + compliance frame results and **revise** the PRD's Section 7 Security and Compliance NFRs. The original NFRs were a first draft; today's are the architecture-level version.

Each updated NFR uses the same template as Week 3 Day 3:

```
### NFR — <short name>
**Category:** Security / Compliance
**Requirement:** <specific>
**Defense:** <why this; tied to STRIDE threat or
compliance frame>
**Verification:** <test or audit method>
```

What changed from Week 3?

Week 3 NFR	Week 4 update	Why
"AuthN: SSO required"	Specifies SAML 2.0 + scope `reconcile.write`	Threat model surfaced privilege scope
"Audit logging"	Specific event list (S/T/R STRIDE coverage)	SOC 2 + Repudiation threats
"Encryption"	Specifies in-transit (TLS 1.2+) + at-rest (managed keys) + log redaction	Information Disclosure threats

The TCD Section 3 is a sibling to PRD Section 7 — it doesn't replace; it deepens.

Deliverable

TCD Section 3 drafted with applicable compliance frames named and a revised Security/Compliance NFR set linking back to STRIDE findings.

Activity 4 — Security Stakeholder Conversation Prep

Format: Triad • **45 min** + Wrap • Block 4

Purpose

The TCD Section 3 will eventually be reviewed by the actual security team. Today the triad rehearses that conversation — what to bring, what to ask, what the security team will most likely push back on.

Setup

Each triad needs the threat model, updated NFRs, TCD Section 3, and the security-brief template. AI permitted for the cross-check; log it.

Triad protocol

1. **List 5 questions you'd ask the security team** (15 min). Examples:

    - "Does our SSO scope model fit the existing Microsoft Entra ID / Azure RBAC patterns?"
    - "Where is the line between 'we mitigate' and 'platform mitigates'?"
    - "What's the precedent for this data classification?"
2. **Predict 3 likely pushbacks from security** (10 min). For each, plan a response.
3. **Draft a 1-page security brief** (15 min) — the document you'd hand to a security partner before the meeting:

```
# Security brief — <feature>
## Summary (3 bullets)
## Data flow (link to TCD Section 2)
## Top 5 threats (from STRIDE pass)
## Open questions for security team
## Decisions we've already made (and their
justification)
```

4. **AI cross-check** (5 min). Use the **Critique-hat prompt** to ask AI: "What's the strongest objection a senior security architect would raise after reading this brief?" Capture the answer; decide if you need to revise.

What "good" looks like

- The brief is **short**: a security partner can read it in 5 minutes.
- The "open questions" list is **specific** — not "tell us about security."
- The "decisions already made" section shows the triad isn't outsourcing thinking; they made a starting point and want validation.

Deliverable

A 1-page security brief plus 5 named questions for the security team and 3 predicted pushbacks with planned responses.

Wrap (last 15 min)

Each triad shares:

- The 1 STRIDE threat that surprised them most
- The 1 NFR that changed materially from the Week 3 first draft

- Their top question for the security team

End-of-day checkpoint

Each triad ends Day 2 with:

- [x] A STRIDE walk through their feature's data flow
- [x] **Top-5 threats** documented with mitigations and owners
- [x] **Updated security and compliance NFRs** (replacing the PRD Section 7 first draft)
- [x] A 1-page **security brief** ready for a security-team conversation
- [x] AI provenance note for any prompts used today
- [x] TCD Section 3 drafted